Ревизия фич планировщика отпусков

Параметр	Значение
Документ	Ревизия фич (документ 0 комплекта)
Версия	1.0
Дата	27.10.2026
Статус	Утверждена как исходная точка этапа 1
Связанные документы	1 — Архитектура и план развития; 3 — Бэклог этапа 1; 8 — ТЗ

1. Назначение

Фиксация фактического состояния инструмента (as-is) и целевого состояния корпоративного планировщика отпусков на компанию до 500 человек (to-be). Документ — основа бэклога этапа 1: каждая строка таблицы 3 имеет адресата в бэклоге.

Исходное состояние: репозиторий `vacation-planner`, монолит из одного SPA-файла `public/index.html` (~4,6 тыс. строк) и тонкого бэкенда `server.js` (Express + SQLite). Рабочих фич много, но архитектура рассчитана на одного пользователя и локальный запуск.

2. Сводка as-is

Область	Состояние	Оценка
График отпусков (Gantt, фильтры, heatmap, minimap)	Работает, рендер O(N×365) DOM-узлов	Сохранить, оптимизировать
Заявки на отпуск с согласованием	Работает, вся логика на клиенте	Перенести на сервер
Баланс дней, лимиты	Считается, лимит не enforced	Перенести на сервер, enforced
Справочники (отделы, проекты, группы)	Работают, хранение в JSON-коллекциях	Перенести в нормальные таблицы
Аналитика (структура, пересечения)	Работает медленно на больших данных	Сохранить, оптимизировать
Аутентификация	Пароли открытым текстом, проверка на клиенте	Заменить полностью
Хранение	SQLite, PUT всего состояния из браузера	Заменить на гранулярный API
Уведомления	Только локальные toast и бейдж	Добавить серверные
Тесты, CI	Отсутствовали до 27.10.2026	Добавлены (этап 0)

3. Ревизия по фичам

Вердикты: **сохранить** — фича переезжает как есть или с косметикой; **переработать** — логика сохраняется, реализация меняется; **заменить** — подход меняется принципиально; **создать** —

фичи нет.

3.1. Сотрудник

Фича	As-is	Проблемы	Вердикт	Этап
Заявка на отпуск: даты, превью календарных/рабочих дней, комментарий	Есть	Валидация только на клиенте; пересечение собственных заявок не проверяется	Переработать (серверная валидация, 409 при пересечении)	1
Баланс: положено / использовано / остаток / на согласовании	Есть	Может уходить в минус, ничем не грозит	Переработать: серверный расчёт; подача сверх лимита — блокируется политикой (п. 5.3 док. 1)	1
Контроль ТК РФ: часть отпуска ≥14 календарных дней подряд	Есть (предупреждение)	Только текущий год	Сохранить, расширить на скользящий год	1
Редактирование своей pending-заявки, перенос approved, запрос на удаление	Есть	Логика статусов на клиенте	Переработать (серверный конечный автомат)	1
История изменений своих заявок	Есть (последние 20)	Хранится в записи, редактируется клиентом	Переработать: серверный журнал	1
Просмотр графика с фильтрами	Есть	Нет частичных обновлений; устаревание после загрузки	Переработать: API + polling обновлений	1–2
Смена своего пароля	Есть	Пароли в открытом виде	Заменить: хеши, серверная смена	1
Личная тема, запоминание фильтров	Есть	—	Сохранить	1
ИП/самозанятые без отпуска	Есть	—	Сохранить	1
Уведомления о решениях по заявкам	Нет (только локальный toast)	—	Создать: центр уведомлений + email	1–2

3.2. Руководитель

Фича	As-is	Проблемы	Вердикт	Этап
Согласование заявок прямых подчинённых (одобрить/отклонить с комментарием)	Есть	Руководитель отдела без прямых подчинённых не согласует; очередь не обновляется без перезагрузки	Переработать: право согласования = руководитель сотрудника по оргструктуре; живое обновление	1
Заявки по проектам (просмотр)	Есть	—	Сохранить	2

Фича	As-is	Проблемы	Вердикт	Этап
Панели отдела и проекта: сводка на сегодня, баннер конфликта	Есть	—	Сохранить	2
Режимы работы подчинённых (офис/удалёнка): недельный шаблон + переопределения	Есть	—	Переработать на API	1
Оформление отпуска за подчинённого (авто-утверждение)	Есть	—	Сохранить	1

3.3. Администратор

Фича	As-is	Проблемы	Вердикт	Этап
CRUD сотрудников, генерация логина-транслита и пароля	Есть	—	Переработать на API	1
Защита «нельзя снять/удалить последнего админа»	Есть (на клиенте)	Не проверяется сервером	Переработать	1
Справочники отделов/проектов/групп, назначение руководителей	Есть	Отдел — строка, целостность не контролируется	Переработать: отдел как сущность с id	1–2
Прямой редактор отпусков любого сотрудника	Есть	Обходит журнал	Переработать: только через заявки с авто-утверждением + аудит	1
Импорт/экспорт XLSX, JSON-бэкап, сброс к seed	Есть	Экспорт отдаёт пароли и устаревшие отпуска (легаси-поле `vacations`); сброс доступен анонимно	Переработать: экспорт без секретов, единый источник данных, сброс только администратору	1
Структура подчинения, орг-диаграмма, статистика по руководителям	Есть	—	Сохранить	2
Пересечения отпусков по отделам и проектам за год	Есть	Пересчёт на клиенте, медленно	Переработать: серверный расчёт	2
Порог конфликта (глобальный)	Есть	Любой пользователь может менять, перезаписывая всё состояние	Переработать: настройка организации, только администратор	1

3.4. Системные свойства

Свойство	As-is	Цель (500 чел.)	Вердикт
Конкурентность	PUT всего состояния, last-write-wins: правки двух пользователей перезаписывают друг друга	Гранулярные операции, транзакции, optimistic-concurrency по заявкам	Заменить (критично)
Актуальность данных	Загрузка один раз при старте	Обновления без перезагрузки (polling 30 с на этапе 1)	Заменить
Безопасность	Пароли открытым текстом; API анонимен; сессия — подделываемый uid в localStorage; XSS через innerHTML; пароли в XLSX-экспорте	Хеши паролей, JWT-сессии, серверная авторизация, экранирование, секреты вне выгрузок	Заменить (критично)
Идентификаторы	`Date.now()` — коллизии при одновременных действиях	Последовательные id из БД	Заменить
Производительность графика	~48 000 DOM-узлов на 131 чел., O(N²×дни) на конфликты	Виртуализация/интервальный рендер, серверный расчёт конфликтов	Переработать
Производственный календарь	Захардкожен 2026 год	Загружаемые календари по годам	Заменить
Часовой пояс	«Сегодня» = UTC-дата — в UTC+N съезжает на вечер	Часовой пояс организации	Заменить
Аудит	История в записи заявки, редактируется клиентом	Серверный журнал действий	Создать
Тесты/CI	Нет (добавлены базовые в этапе 0)	Линтер, тесты, контракт, дым — на каждый PR	Создать
Резервное копирование	Нет	Ежедневный бэкап SQLite + проверка восстановления	Создать
Развёртывание	`start.bat` на Windows	Docker Compose / systemd на Linux-стенде	Создать

4. Главные пробелы для компании на 500 человек

1. **Двухфазная запись состояния.** Любое действие пользователя отправляет на сервер весь снимок данных организации (131 чел. ≈ 274 КБ, 500 чел. ≈ 1–1,5 МБ). При одновременной работе теряются данные. Это блокирующий дефект № 1.
2. **Отсутствие серверной авторизации.** Все проверки прав — в браузере; API принимает любые записи без аутентификации, включая `POST /api/reset`, уничтожающий данные организации.
3. **Пароли в открытом виде** в БД, в каждом `GET /api/state` и в XLSX-выгрузке.
4. **Отсутствие обновлений в реальном времени**: заявка, поданная после загрузки страницы, не появится у согласующего без перезагрузки.
5. **Год зашит в код** (список дат 2026, праздники 2026, подписи «перенос с 2025») — 1 января 2027 система перестаёт быть применимой.
6. **XSS через импорт**: имена и комментарии вставляются в innerHTML без экранирования.
7. **Нет аудита**: кто и когда изменил/удалил отпуск, восстановить невозможно.

5. Что сознательно не входит в этап 1

- Интеграция с 1С/ЗУП, кадровые приказы, больничные — этап 3 (документ 1, раздел 16).
- Мобильное приложение — этап 3 (адаптивная верстка — этап 2).
- Мультиорганизационность (несколько юрлиц в одном экземпляре) — этап 3.
- Замена SQLite на PostgreSQL — по факту нагрузки; решение и критерии — ADR-004.